

INFORME SOBRE AUDITORÍA DE SEGURIDAD: SafeFilms

- *Mbarek Galloul Ezzakraoui*
- *Alicia Maizkurrena*
- *Adrián Vinagre*
- *Maira Gabriela Herbas*
- *Ana Victoria Cernatescu*

Herramientas: OWASP ZAP 2.16.1

Índice

Índice.....	1
Introducción.....	2
Resultados de la auditoría con ZAP.....	2
Alerta 1: Inyección SQL.....	2
Alerta 2: Inyección SQL (2).....	4
Alerta 3: Ausencia de Tokens Anti-CSRF.....	5
Alerta 4: Cabecera Content Security Policy (CSP) no configurada.....	7
Alerta 5: Divulgación de error de aplicación.....	8
Alerta 6: Falta de cabecera Anti-Clickjacking.....	9
Alerta 7: Manipulación de parámetros.....	10
Alerta 8 : Cookie sin flag HttpOnly.....	11
Alerta 9: Cookie sin el atributo SameSite.....	13
Alerta 10: El servidor divulga información mediante un campo de encabezado de respuesta HTTP ``X-Powered-By``.....	14
Alerta 11: El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP.....	16
Alerta 12: Falta encabezado X-Content-Type-Options.....	17
Alerta 13: Aplicación Web Moderna.....	18
Alerta 14: Atributo de elemento HTML controlable por el usuario (XSS potencial).....	19
Alerta 15: Divulgación de Información - Información sensible en URL.....	20
Alerta 16: Respuesta de Gestión de Sesión Identificada.....	20
Otras posibles mejoras.....	21
Conclusión.....	21

Introducción

El objetivo de esta entrega es realizar una auditoría sobre entrega_1.

Resultados de la auditoría con ZAP

Informe de primera auditoría, generado utilizando ZAP:  InformeSafeFilms1.pdf

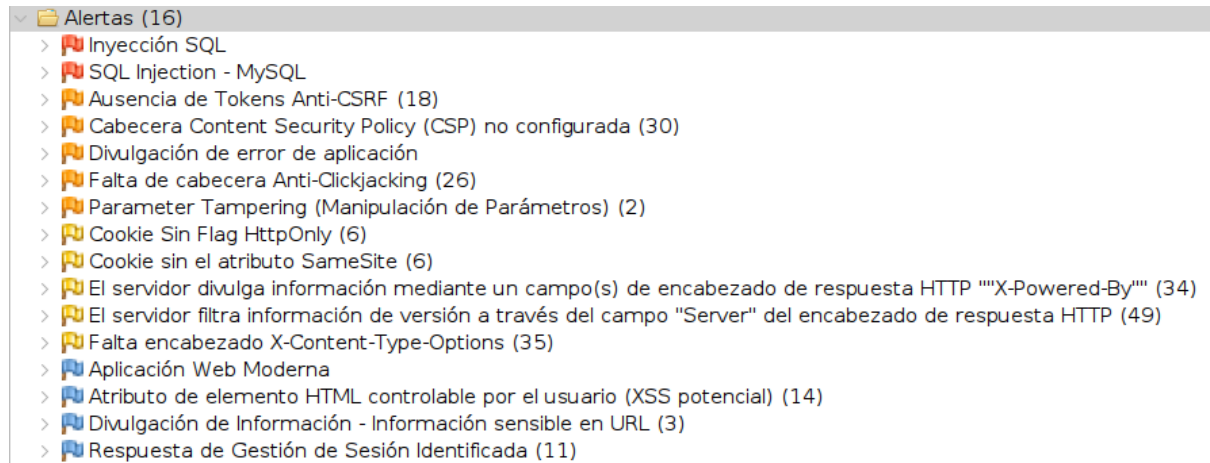


Imagen de segunda auditoría, con mayor cantidad de alertas.

Alerta 1: Inyección SQL

Petición:

POST http://localhost:81/login.php HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer: http://localhost:81/login.php
content-length: 88
Cookie: PHPSESSID=b4bb1ffc37bfa2ecf95177b2d3ed49a7

usuario=ZAP%27+AND+%271%27%3D%271%27+--+&contrasena=ZAP&login_submit=Iniciar+sesi%C3%B3n

Respuesta:

HTTP/1.1 302 Found
Date: Wed, 29 Oct 2025 14:40:50 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

Location: items.php

Content-Length: 0

Content-Type: text/html; charset=UTF-8

Clasificación:

- [CWE-89](#) : Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

El producto construye parte de una instrucción sql en inputs del usuario y la aplicación los interpreta como parte de una instrucción SQL en vez de datos del usuario.

- [HIPAA](#) : Health Insurance Portability and Accountability Act

Etiqueta que representa alertas o reglas asignadas al estándar HIPAA. Relaciona la inyección con los datos médicos de un usuario.

- [OWASP_2017_A01](#) : Injection

Casi cualquier vector puede ser un vector de inyección.

- [OWASP_2021_A03](#) : Injection

Los datos enviados no se validan correctamente o las consultas dinámicas no se parametrizan o no se codifican los parámetros.

- [PCI_DSS](#) : Payment Card Industry Data Security Standard

Etiqueta que representa alertas o reglas asignadas al estándar HIPAA. Relaciona la inyección con el riesgo en los datos de pago.

- [WSTG-v42-INPV-05](#) : Web Security Testing Guide versión 4.2

Busca si hay vulnerabilidad de inyección SQL tal que en la aplicación se puede usar user input para crear sentencias SQL.

- POLICY_API
- POLICY_DEV_CICD
- POLICY_DEV_FULL
- POLICY_DEV_STD
- POLICY_PENTEST
- POLICY_QA_CICD
- POLICY_QA_FULL
- POLICY_QA_STD
- POLICY_SEQUENCE

Riesgo: Alto

Confianza: Media

Descripción:

Esta alerta ocurre porque la sentencia SQL que tenemos en *login.php* para comprobar si el usuario existe no se valida ni se limpia, directamente se manda. Nuestra sentencia es:

```
$sql = "SELECT idU, usuario, contrasena from usuarios where usuario =  
'" . $usuario . "'";
```

Lo que hace ZAP, al loggarse inserta como usuario ' OR '1'=1 y por lo tanto se ejecuta:
SELECT idU, usuario, contrasena from usuarios where usuario = ' ' OR '1'=1'

Como 1=1, consigue violar ese campo pero como luego comprobamos la contraseña por php, no accede directamente a la aplicación. Aún así, es un problema grave porque puede afectar a la protección de datos del usuario.

Alerta 2: Inyección SQL (2)

Petición:

POST http://localhost:81/register.php HTTP/1.1

host: localhost:81

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/131.0.0.0 Safari/537.36

pragma: no-cache

cache-control: no-cache

content-type: application/x-www-form-urlencoded

referer: http://localhost:81/register.php

content-length: 160

Cookie: PHPSESSID=f0fdd378efc7fc3916a42b6d431d4d12

nombre=ZAP&apellido=ZAP&numDni=ZAP&letraDni=ZAP&tlf=ZAP&fNacimiento=2025-10-29&email=zaproxy%40example.com&usuario=%27&contrasena=ZAP®ister_submit=Registrar

Respuesta:

HTTP/1.1 200 OK

Date: Wed, 29 Oct 2025 14:40:51 GMT

Server: Apache/2.4.25 (Debian)

X-Powered-By: PHP/7.2.2

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

Vary: Accept-Encoding

Content-Length: 1599

Content-Type: text/html; charset=UTF-8

(Envía html de register)

Clasificación: (las mismas que la alerta anterior)

- CWE-89
- HIPAA
- OWASP_2017_A01
- OWASP_2021_A03
- PCI_DSS
- POLICY_API
- POLICY_DEV_CICD
- POLICY_DEV_FULL
- POLICY_DEV_STD
- POLICY_PENTEST
- POLICY_QA_CICD
- POLICY_QA_FULL
- POLICY_QA_STD
- POLICY_SEQUENCE
- WSTG-v42-INPV-05

Riesgo: Alto

Confianza: Media

Descripción:

La alerta nos salta porque en *register.php* insertamos los datos prácticamente de manera directa a la base de datos. En principio podríamos pensar que la inyección no tiene importancia pero se podrían insertar instrucciones como drop table usuarios .

Alerta 3: Ausencia de Tokens Anti-CSRF

Petición:

GET http://localhost:81/login.php HTTP/1.1

host: localhost:81

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/131.0.0.0 Safari/537.36

pragma: no-cache

cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK

Date: Wed, 29 Oct 2025 14:38:26 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=1dc8b38ceb233c0d0d8dc4ba5f330bb4; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 680
Content-Type: text/html; charset=UTF-8

(Envía html de login)

Clasificación:

- [CWE-352](#) : Cross-Site Request Forgery

La aplicación no verifica que la petición haya sido enviada de manera no intencional por un usuario o por un actor sin autorizar.

- [OWASP_2017_A05](#) : Broken Access Control

Ausencia de control de acceso.

- [OWASP_2021_A01](#) : Broken Access Control
- [WSTG-v42-SESS-05](#) : Testing for Cross Site Request Forgery

Obliga a un usuario a ejecutar acciones no deseadas en una aplicación web en la que está autenticado. Un atacante puede forzar a los usuarios a realizar acciones elegidas por el atacante.

- POLICY_DEV_STD
- POLICY_PENTEST
- POLICY_QA_STD
- [SYSTEMIC](#)

Este aviso incluye la etiqueta “Systemic”, la cual denota que se trata de una alerta que afecta a todo el sitio web. Normalmente este tipo de avisos tienen que ver con las reglas sobre las cabeceras.

Riesgo: Medio

Confianza: Baja

Descripción:

El aviso nos salta en *login.php* porque no comprobamos en ningún momento que la petición es enviada intencionalmente por un usuario. Un atacante podría forzar que el formulario se envíe desde otro sitio o engañar al navegador del usuario para mandar formularios.

Alerta 4: Cabecera Content Security Policy (CSP) no configurada

Petición:

GET http://localhost:81/robots.txt HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache

Respuesta:

HTTP/1.1 404 Not Found
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
Content-Length: 283
Content-Type: text/html; charset=iso-8859-1

Clasificación:

- [CWE-693](#) : Protection Mechanism Failure

El producto no utiliza un mecanismo de protección que ofrezca suficiente seguridad contra posibles ataques directos al producto, o lo utiliza incorrectamente.

- [OWASP_2021_A05](#) : Security Misconfiguration

Entre muchos otros errores de configuración, el servidor no envía cabeceras o directivas de seguridad, o no se envían correctamente.

- [OWASP_2017_A06](#) : Security Misconfiguration
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)

Riesgo: Medio

Confianza: Alta

Descripción:

El servidor no incluye cabecera HTTP Content Security Policy en las respuestas. En este caso, se hace una petición de la página `http://localhost:81/robots.txt`, la cual no existe. Al aparecer la cabecera de error, no aparecen los encabezados HTTP estándar que proporciona CSP.

Los encabezados HTTP estándar proporcionados por CSP permiten a los propietarios de la página establecer fuentes específicas de contenido que el navegador puede cargar y ejecutar. Además, ayudan a mitigar y detectar ciertos tipos de ataques, como Cross Site Scripting (XSS) e inyección de datos.

Además, la alerta nos salta por todas las páginas (*es decir, login.php, modify_user, etc*) porque no lo hemos especificado en el header de su parte html.

Alerta 5: Divulgación de error de aplicación

Petición:

```
POST http://localhost:81/register.php HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer: http://localhost:81/register.php
content-length: 160
Cookie: PHPSESSID=ec83fe7002c5223f1c44324c211545a0
```

Respuesta:

```
HTTP/1.1 200 OK
Date: Wed, 29 Oct 2025 20:59:42 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 306
Content-Type: text/html; charset=UTF-8
```

Clasificación:

- [OWASP_2021_A05](#) : Security Misconfiguration
- [OWASP_2017_A06](#) : Security Misconfiguration
- [WSTG-v42-ERRH-02](#): Testing for Stack Traces
- [WSTG-v42-ERRH-01](#): Testing for Improper Error Handling

Cuando se generan errores, la aplicación no los maneja correctamente, y por tanto se muestran como: seguimientos de pila, errores de conexión con la red, incompatibilidad de datos de entrada, volcados de memoria (contenido de un registro desordenado en un momento específico). Esta información puede ser visible para un posible atacante, y le ayuda a entender cómo funciona la aplicación.

- **CWE-550:** Server-generated Error Message Containing Sensitive Information

Ciertas condiciones, como un fallo en la red, pueden hacer que se produzca un mensaje de error, que otorga información a un posible atacante.

Riesgo: Medio

Confianza: Media

Descripción:

Esta página contiene un mensaje de error/advertencia que podría revelar información sensible como la ubicación del archivo que produjo la excepción no controlada. Esta información puede ser usada para lanzar futuros ataques contra la aplicación web. La alerta podría ser una falso positivo si el mensaje de error es encontrado dentro de una página de documentación.

En nuestro caso, si ocurre un error, como por ejemplo un error en la inicialización de la base de datos, se muestra el error en la página y se muestra la ubicación del archivo donde ocurre el error.

Alerta 6: Falta de cabecera Anti-Clickjacking

Petición:

```
GET http://localhost:81/ HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
```

Respuesta:

```
HTTP/1.1 200 OK
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=2e1ce2ef62a38ec0677ed509718914b8; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 641
Content-Type: text/html; charset=UTF-8
```

Clasificación:

- [OWASP_2021_A05](#) : Security Misconfiguration
- POLICY_QA_STD =
- POLICY_PENTEST =
- [CWE-1021](#) : Improper Restriction of Rendered UI Layers or Frames

La aplicación no restringe correctamente el uso de “frames” o “iframes” que pertenezcan a otras aplicaciones o dominios.

- [SYSTEMIC](#)
- [WSTG-v42-CLNT-09](#) : Testing for Clickjacking

Un posible atacante puede añadir la aplicación a su propia página web sin ninguna restricción, utilizando funciones HTML y JavaScript aparentemente inofensivas, pero que confunden al usuario de tal manera que le convencen de interactuar en la aplicación mediante su web maliciosa sin que el usuario lo sepa..

- [OWASP_2017_A06](#) : Security Misconfiguration

Riesgo: Medio

Confianza: Alta

Descripción:

La respuesta no incluye protección contra clickjacking. Falta incluir CSP con la directiva “frame ancestors” o utilizar X-Frame-Options. Es decir, otras entidades pueden usar esta aplicación para introducirla en un contenedor (iframe) dentro de su propia página web sin restricción.

Esto otorga demasiada libertad, pudiendo hacer dicho contenedor invisible, por ejemplo. Así, pueden surgir confusiones, como que un usuario no tenga claro con qué aplicación está interactuando realmente, e introduzca datos o haga click en botones de la aplicación no deseada sin saberlo.

Esta alerta nos salta en todas las clases por la falta de la cabecera en el servidor, entonces es algo que se debería de solucionar en todas las respuestas que nuestro servidor envía al navegador.

Alerta 7: Manipulación de parámetros

Petición:

```
POST http://localhost:81/register.php HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
```

referer: http://localhost:81/register.php
content-length: 150
Cookie: PHPSESSID=ec83fe7002c5223f1c44324c211545a0

Respuesta:

HTTP/1.1 200 OK
Date: Wed, 29 Oct 2025 21:00:13 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 306
Content-Type: text/html; charset=UTF-8

(Envía html de register)

Clasificación:

- [OWASP_2021_A04](#): Insecure Design
- [OWASP_2017_A01](#): A1:2017-Injection
- [CWE-472](#): External Control of Assumed-Immutable Web Parameter
- POLICY_API
- POLICY_DEV_FULL
- POLICY_QA_FULL

Riesgo: Medio

Confianza: Baja

Descripción:

La manipulación de parámetros provocó que se mostrará una página de error o un rastreo de pila de Java. Esto indica una falta de manejo de excepciones y posibles áreas para poder ser explotado en el futuro.

La alerta nos salta en *register.php* porque insertamos la información del usuario (nombre, email...) directamente con un POST, por lo que un atacante podría cambiar valores, como por ejemplo el usuario que es, y el servidor acepta esos valores, por lo que se puede hacer pasar por otros usuarios.

Alerta 8 : Cookie sin flag HttpOnly

***** Aplicable para la alerta 9, 10 y 11 también *****

Riesgo: Bajo

Confianza: Media

***** _ *****

Petición:

GET http://localhost:81/ HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=2e1ce2ef62a38ec0677ed509718914b8; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 641
Content-Type: text/html; charset=UTF-8

Clasificación:

- [CWE-1004](#) : Sensitive Cookie Without 'HttpOnly' Flag

La aplicación utiliza cookies para almacenar contenido sensible, pero esas cookies no tienen el flag 'HttpOnly'.

- [OWASP 2021_A05](#) : Security Misconfiguration
- POLICY_QA_STD =
- [WSTG-v42-SESS-02](#) : Testing for Cookies Attributes

Los navegadores utilizan varios mecanismos para almacenar información sobre las sesiones de los usuarios. El más utilizado son las cookies. Para evitar que terceros accedan a esta información, se han desarrollado atributos y prefijos para las cookies, como el prefijo 'HttpOnly'.

- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP_2017_A06](#) : Security Misconfiguration
- POLICY_DEV_STD =

Descripción:

Se ha establecido una cookie sin el flag HttpOnly, lo que significa que JavaScript puede acceder a la cookie. Si un script malicioso puede ser ejecutado en esa página, entonces la cookie será accesible y se podrá retransmitir a otros sitios, teniendo riesgo de secuestro de sesión.

Esto se debería solucionar configurando todas las cookies que el servidor envía al navegador para que incluyan la flag.

Alerta 9: Cookie sin el atributo SameSite

Petición:

```
GET http://localhost:81/ HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows
NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/131.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
```

Respuesta:

```
HTTP/1.1 200 OK
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie:
PHPSESSID=be80ba5985ff2b0471aa0d571
82cfd0d; path=/
Expires: Thu, 19 Nov 1981 08:52:00
GMT
Cache-Control: no-store, no-cache,
must-revalidate
Pragma: no-cache
```

Vary: Accept-Encoding
Content-Length: 641
Content-Type: text/html;
charset=UTF-8

Clasificación:

- [OWASP_2021_A01](#) : Broken Access Control

El control de acceso impulsa una política que explica que los usuarios no pueden interactuar con cualquier elemento de la aplicación si no tienen permiso para ello. Unos ejemplos de romper el control de acceso de una web podrían ser: Poder utilizar funcionalidades de administrador siendo usuario, poder utilizar funcionalidades de usuario sin estar identificado, poder conseguir, modificar, o eliminar información de otros usuarios sin autorización...

- POLICY_QA_STD =
- [WSTG-v42-SESS-02](#) : Testing For Cookies Attributes
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-1275](#) : Sensitive Cookie With Improper SameSite Attribute

El valor 'SameSite de' una cookie está mal establecido o no está establecido. El atributo 'SameSite' maneja cómo se envían las cookies cuando se hacen peticiones entre distintos dominios. Dicho atributo puede tener los valores: 'Lax', 'Strict' o 'None'. Si el atributo está fijado en 'None', cuando se haga una petición desde otro dominio, el navegador automáticamente añadirá cookies a esta petición, aumentando el riesgo de ataque de falsificación de solicitud entre sitios (Cross-Site-Request-Forgery, CSRF).

- [OWASP_2017_A05](#) : Broken Access Control
- POLICY_DEV_STD =

Descripción:

Se ha establecido una cookie sin el atributo 'SameSite', lo que quiere decir que la cookie podría ser enviada en una solicitud 'Cross-Site', es decir, podría ser enviada como una petición desde otra web. Si una web maliciosa envía una solicitud, se le podría enviar la cookie y podría efectuar cambios en la cuenta de un usuario como si fuesen cambios legítimos de dicho usuario, ya que la cookie tiene la información de la sesión del usuario guardada.

Alerta 10: El servidor divulga información mediante un campo de encabezado de respuesta HTTP ``X-Powered-By``

Petición:

GET http://localhost:81/ HTTP/1.1
host: localhost:81

user-agent: Mozilla/5.0 (Windows
NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/131.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie:
PHPSESSID=2e1ce2ef62a38ec0677ed5097
18914b8; path=/
Expires: Thu, 19 Nov 1981 08:52:00
GMT
Cache-Control: no-store, no-cache,
must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 641
Content-Type: text/html;
charset=UTF-8

Clasificación:

- [OWASP_2021_A01](#) : Broken Access Control
- [WSTG-v42-INFO-08](#) : Fingerprint Web Application Network
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP_2017_A03](#) : Sensitive Data Exposure

Se transmite información sensible en texto plano, sin ningún tipo de encriptación ni medidas de seguridad para que la información esté oculta o no legible.

- [CWE-497](#) : Exposure of Sensitive System Information to an Unauthorized Control Sphere

El producto no previene que actores no autorizados tengan acceso a información sensible a nivel de sistema. Generalmente las aplicaciones web funcionan utilizando un sistema operativo, y se espera que cuando el producto se comuniquen con partes externas a él mismo, la información sensible sobre el sistema, se mantenga oculta. Ejemplos de esta información son: paquetes o librerías instaladas, carpetas, usuarios ...

Descripción:

El servidor de la web está divulgando información sensible mediante uno o más encabezados HTTP de respuesta "X-Powered-By". Esta información puede ser útil para posibles atacantes.

El error nos salta en varias páginas porque el encabezado X-Powered-By revela la versión de PHP que utilizamos, dando información que no debería y pudiendo favorecer a ataques, ya que un atacante puede usar vulnerabilidades concretas de la versión que se utiliza.

Alerta 11: El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP

Petición:

```
GET http://localhost:81/inicioStyle.css HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
referer: http://localhost:81/
Cookie: PHPSESSID=be80ba5985ff2b0471aa0d57182cfd0d
```

Respuesta:

```
HTTP/1.1 200 OK
Date: Tue, 28 Oct 2025 15:44:34 GMT
Server: Apache/2.4.25 (Debian)
Last-Modified: Thu, 23 Oct 2025 12:18:22 GMT
ETag: "1497-641d26de4acf6"
Accept-Ranges: bytes
Content-Length: 5271
Vary: Accept-Encoding
Content-Type: text/css
```

Clasificación:

- [OWASP_2021_A05](#) : Security Misconfiguration
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP_2017_A06](#) : Security Misconfiguration
- [WSTG-v42-INFO-02](#) : Fingerprint Web Server

No se oculta la información del servidor y su versión utilizada para poder mostrar el sitio web. Por culpa de esto se tiene más información de las vulnerabilidades específicas de dicho servidor en su versión concreta.

- [CWE-497](#) : Exposure of Sensitive System Information to an Unauthorized Control Sphere

El sistema no previene que información sensible sobre el sistema pueda ser accedida por actores no autorizados.

Riesgo: Bajo

Confianza: Alta

Descripción:

El servidor de la aplicación filtra información sobre su versión mediante la cabecera de sus respuestas. El acceso a esta información facilita que se encuentren ataques y vulnerabilidades específicos para la versión del servidor, y se pueda realizar un mejor ataque más sencillamente.

Alerta 12: Falta encabezado X-Content-Type-Options

Petición:

GET http://localhost:81/ HTTP/1.1

host: localhost:81

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/131.0.0.0 Safari/537.36

pragma: no-cache

cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK

Date: Thu, 30 Oct 2025 11:22:56 GMT

Server: Apache/2.4.25 (Debian)

X-Powered-By: PHP/7.2.2

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

Vary: Accept-Encoding

Content-Length: 306

Content-Type: text/html; charset=UTF-8

Clasificación:

- [CWE-693](#) : Protection Mechanism Failure

El producto no utiliza un mecanismo que ofrezca suficiente seguridad contra posibles ataques directos al producto, o lo utiliza incorrectamente.

- [OWASP_2021_A05](#) : Security Misconfiguration

Entre muchos otros errores de configuración, el servidor no envía cabeceras o directivas de seguridad, o no se envían correctamente.

- [OWASP_2017_A06](#) : Security Misconfiguration

Riesgo: Bajo

Confianza: Media

Descripción:

El cuerpo de la respuesta se ha interpretado como un tipo de contenido distinto al declarado y se muestra como dicho tipo. Por ejemplo, si se usa Firefox, el navegador usará el tipo de contenido declarado en vez de realizar un proceso de MME-sniffing.

Alerta 13: Aplicación Web Moderna

Petición: Alta

GET http://localhost:81/ HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK
Date: Thu, 30 Oct 2025 11:14:08 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=313503eee5e43996a90a9365a7158ad2; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate

Clasificación: [Vacía]

Riesgo: Informativo

Confianza: Media

Descripción:

Se examinan los parámetros de entrada proporcionados por el usuario y los datos POST para saber dónde podrían estar controlados por valores de atributos HTML. Gracias al examen tendremos cross-site scripting, que un analista de seguridad determinará su explotabilidad de ellos.

Alerta 14: Atributo de elemento HTML controlable por el usuario (XSS potencial)

Petición:

GET http://localhost:81/items.php?search=%3Cscript%3Ealert('XSS')%3C/script%3E
HTTP/1.1

host: localhost:81

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

Respuesta:

HTTP/1.1 200 OK

Date: Wed, 29 Oct 2025 16:12:37 GMT

Server: Apache/2.4.25 (Debian)

X-Powered-By: PHP/7.2.2

Content-Type: text/html; charset=UTF-8

Clasificación:

CWE-79 : Cross-site Scripting (XSS)

OWASP_2021_A03 : Injection

WSTG-v42-CLNT-01 : Testing for Reflected Cross Site Scripting

POLICY_PENTEST

SYSTEMIC

Riesgo: Informativo

Confianza: Media

Descripción:

ZAP detecta que en el sistema SafeFilms se pueden introducir parámetros que se muestran en pantalla sin validación previa.

Esto ocurre, por ejemplo, en items.php, donde el valor que se introduce en la búsqueda del catálogo se refleja directamente en el HTML.

Si un usuario malicioso añade código como <script>alert('XSS')</script>, este se ejecuta en el navegador. Esto puede ser aprovechado para mostrar mensajes no deseados o robar cookies de sesión. Para evitarlo, hay que escapar los datos antes de mostrarlos y aplicar cabeceras como Content-Security-Policy (CSP).

Alerta 15: Divulgación de Información - Información sensible en URL

Petición:

GET http://localhost:81/show_user?user=ana&dni=12345678A HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

Respuesta:

HTTP/1.1 200 OK
Date: Wed, 29 Oct 2025 16:25:11 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Content-Type: text/html; charset=UTF-8

Clasificación:

CWE-598 : Information Exposure Through Query Strings in GET Request
OWASP_2021_A01 : Broken Access Control
OWASP_2021_A02 : Cryptographic Failures
WSTG-v42-INFO-04 : Review URL for Sensitive Information

Riesgo: Informativo

Confianza: Alta

Descripción:

ZAP detecta que el sistema *SafeFilms* envía datos personales a través de la URL al acceder al perfil del usuario, por ejemplo en la ruta “**show_user.php?user=ana&dni=12345678A**”.

Esto puede exponer información sensible, ya que las direcciones URL se guardan en el historial del navegador, en los registros del servidor o pueden compartirse por accidente.

Aunque el sistema solo muestra la información básica del usuario, sigue siendo una práctica insegura porque permite identificar fácilmente a una persona.

Para solucionarlo, se recomienda **usar el método POST** en lugar de GET para enviar datos sensibles, **no incluir identificadores personales en las URLs** y **usar HTTPS** para cifrar la comunicación y evitar que los datos puedan ser vistos por terceros.

Alerta 16: Respuesta de Gestión de Sesión Identificada

Petición:

GET http://localhost:81/ HTTP/1.1
host: localhost:81
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36

pragma: no-cache
cache-control: no-cache

Respuesta:

HTTP/1.1 200 OK
Date: Thu, 30 Oct 2025 11:14:08 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=313503eee5e43996a90a9365a7158ad2; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate

Clasificación: [Vacía]

Riesgo: Informativo

Confianza: Media

Descripción:

La respuesta que se recibe contiene un token de gestión de sesión. Por otro lado, el campo 'Other Info' contiene un conjunto de tokens que pueden ser utilizados como cabeceras dentro de dicha gestión. En el caso de que se encuentre el método "Auto-Detect" se cambiará la forma de gestionar los tokens identificados.

Otras posibles mejoras

Como medidas de seguridad no mencionadas en la sección anterior, hemos pensado lo siguiente:

- Que todo el mundo pueda ver el catálogo pero solo los usuarios identificados puedan modificar las películas.
- La creación de un super usuario, que solo él sea el encargado de borrar y añadir películas (es decir, un administrador).
- A la hora de registrar un usuario, guardamos la contraseña sin más cuando lo ideal sería almacenarla usando funciones hash.
- También sería mejor ocultar la contraseña en el momento en el que el usuario la está escribiendo tanto al loguearse como al iniciar sesión.

Conclusión

Después de la auditoría realizada, podemos clasificar las alertas a solucionar para la entrega 3 en las siguientes vulnerabilidades:

Tipo de vulnerabilidad	Alertas
------------------------	---------

Rotura de control de acceso	● Manipulación de parámetros (a.7)
Inyección	● Inyección SQL (a.1) ● Inyección SQL (2) (a.2) ● Atributo de elemento HTML controlable por el usuario (XSS potencial) (a.14)
Diseño inseguro	● Ausencia de tokens Anti-CSRF (a.3)
Configuración de seguridad insuficiente	● Cabecera Content Security Policy (CSP) no configurada (a.4) ● Falta de cabecera Anti-Clickjacking (a.6) ● El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP (a.11) ● El servidor divulga información mediante campo(s) de encabezado de respuesta HTTP ``X-Powered-By`` (a.10) ● Falta encabezado X-Content-Type-Options (a. 12) ● Divulgación de información - Información sensible en URL (a.15)
Fallos de identificación y autenticación	● Cookie sin flag HttpOnly (a.8) ● Cookie sin el atributo SameSite (a.9) ● Respuesta de Gestión de Sesión Identificada (a.16)
Fallos en la integridad de datos	● Divulgación de información - Información sensible en URL (a.15)

En cuanto al apartado de posibles mejoras, estas resolverían los siguientes tipos de vulnerabilidades:

Tipo de vulnerabilidad	Posible mejora
Rotura de control de acceso	● Solo usuarios identificados modifiquen películas ● Solo super usuario pueda añadir y eliminar películas
Fallos criptográficos	● Almacenar contraseñas usando funciones hash
Fallos de identificación y autenticación	● Ocultar contraseña cuando se escribe
Diseño inseguro	● Solo super usuario pueda añadir y eliminar películas